ThreatSimGPT Data Breach Response Framework

Document Control

Field	Information
Version	1.0
Last Updated	January 15, 2026
Next Review	September 15, 2026
Owner	ThreatSimGPT
Author	Jeremiah Okino
Classification	Internal Use - Confidential

Regulatory Framework

This framework aligns with the following regulatory requirements:

- **GDPR Articles 33-34** (Data Breach Notifications)
- **CCPA/CPRA** (California Privacy Rights Act)
- **NIST Cybersecurity Framework (CSF)** - PR.AA-1, PR.AA-2, PR.AA-3
- **ISO 27001:2022** Annex A.16 (Incident Management)
- **SOC 2 Type II** - Security Common Criteria

Executive Summary

This framework establishes the formal methodology for detecting, assessing, containing, and reporting data breaches affecting ThreatSimGPT systems and customer data. It ensures regulatory compliance while maintaining operational security and customer trust.

Scope

Applies to all data processing activities within ThreatSimGPT production environments, including:

- **Customer PII and PHI**
- **System authentication data**
- **Usage analytics and behavioral data**
- **Third-party integrated data**
- **Internal employee and contractor data**

Document Activation

This framework is activated upon:

1. **Confirmed unauthorized access** to personal data
2. **Suspected data exfiltration attempts**

3. **System compromise** affecting data confidentiality
4. **Insider threat incidents** involving personal data
5. **Third-party breach** impacting ThreatSimGPT data

---

1. INCIDENT CLASSIFICATION MATRIX

1.1 Severity Levels

🔴 CRITICAL (Level 4)

- **Large-scale data breach** (>10,000 records)
- **Highly sensitive data exposure** (PII, PHI, financial)
- **System-wide compromise**
- **Regulatory reporting within 24 hours** required

🟠 HIGH (Level 3)

- **Medium-scale breach** (1,000-10,000 records)
- **Sensitive data exposure**
- **Multiple systems affected**
- **Regulatory reporting within 48 hours** required

🟡 MEDIUM (Level 2)

- **Small-scale breach** (<1,000 records)
- **Limited data types affected**
- **Single system impact**
- **Regulatory reporting within 72 hours**

🟢 LOW (Level 1)

- **Minimal data exposure** (<100 records)
- **Non-sensitive data only**
- **Contained immediately**
- **Documentation only**, no notification required

1.2 Data Classification

Classification	Data Types
CONFIDENTIAL	PII, PHI, financial data, credentials
INTERNAL	Usage data, analytics, business data
PUBLIC	Marketing materials, documentation

---

2. SUPERVISORY AUTHORITY NOTIFICATION PROTOCOL (GDPR Article 33)

2.1 Notification Timeline Matrix

Severity	Timeline
🔴 **CRITICAL**	Within 24 hours of discovery
🟠 **HIGH**	Within 48 hours of discovery
🟡 **MEDIUM**	Within 72 hours of discovery
🟢 **LOW**	Documentation only

2.2 Initial Notification Template

```
THREATSIMGPT
DATA BREACH NOTIFICATION TO SUPERVISORY AUTHORITY
Reference: DB-2026-001
Date: [YYYY-MM-DD HH:MM UTC]
Classification: [CRITICAL/HIGH/MEDIUM/LOW]

NOTIFYING AUTHORITY: [Authority Name]
AUTHORITY CONTACT: [Contact Information]

DATA CONTROLLER INFORMATION
==========================
Legal Entity: ThreatSimGPT
Registration: Open Source Project
DPO Contact: threatsimgpt@gmail.com
Emergency Contact: threatsimgpt@gmail.com

INCIDENT OVERVIEW
=================
Incident ID: INC-2026-XXX
Discovery Date/Time: [YYYY-MM-DD HH:MM UTC]
Incident Start Date/Time: [YYYY-MM-DD HH:MM UTC] (if known)
Reporting Date/Time: [YYYY-MM-DD HH:MM UTC]

BREACH CLASSIFICATION
=====================
Severity Level: [CRITICAL/HIGH/MEDIUM/LOW]
Data Categories Compromised:
[ ] Personal Identifiable Information (PII)
[ ] Protected Health Information (PHI)
[ ] Financial Information
[ ] Authentication Credentials
[ ] Behavioral/Usage Data
[ ] Other: [Specify]

QUANTIFIED IMPACT
=================
Data Subjects Affected:
```

```
[ ] Exact Count: [Number]
[ ] Estimated Range: [Min] - [Max]
[ ] Unknown - Investigation Ongoing

Records Compromised:
[ ] Exact Count: [Number]
[ ] Estimated Range: [Min] - [Max]
[ ] Unknown - Investigation Ongoing

Geographic Distribution:
[ ] EU/EEA: [Count/Percentage]
[ ] United Kingdom: [Count/Percentage]
[ ] United States: [Count/Percentage]
[ ] Other: [Specify]

INCIDENT NARRATIVE
==================
[Brief factual description of the incident, including:
- How the breach was discovered
- Immediate containment actions taken
- Current investigation status
- Preliminary root cause assessment]

RISK ASSESSMENT
===============
Likelihood of Harm to Data Subjects:
[ ] Very High - Immediate danger of identity theft/financial loss
[ ] High - Significant risk of privacy violation
[ ] Medium - Moderate risk to privacy rights
[ ] Low - Minimal impact on data subjects
[ ] No Risk - Data encrypted/anonymized

Potential Consequences:
- Identity theft risk: [Yes/No/Partial]
- Financial loss risk: [Yes/No/Partial]
- Reputational damage: [Yes/No/Partial]
- Discrimination risk: [Yes/No/Partial]
- Physical safety risk: [Yes/No/Partial]

RESPONSE ACTIONS TAKEN
======================
Immediate Containment:
1. [Action taken] - [Timestamp] - [Owner]
2. [Action taken] - [Timestamp] - [Owner]
3. [Action taken] - [Timestamp] - [Owner]

Remediation Measures:
1. [Action taken] - [Timestamp] - [Owner]
2. [Action taken] - [Timestamp] - [Owner]
3. [Action taken] - [Timestamp] - [Owner]

Data Subject Communication:
```

```
[ ] Completed - [Date] - [Method]
[ ] In Progress - [Expected Date]
[ ] Not Required - [Justification]
[ ] Planned - [Scheduled Date]

INVESTIGATION STATUS
====================
[ ] Ongoing - Next update: [Date]
[ ] Preliminary findings only
[ ] Root cause identified
[ ] Complete - Full report available

ADDITIONAL INFORMATION
======================
[ ] This is a complete notification
[ ] Additional information to follow by: [Date]

Pending Information:
- [Item 1] - Expected: [Date]
- [Item 2] - Expected: [Date]

Attachments:
[ ] Technical Forensics Report
[ ] Risk Assessment Document
[ ] Data Subject Communication Draft
[ ] Business Impact Analysis
[ ] Other: [Specify]

DECLARATION
===========
I, the undersigned, confirm that:
1. All information provided is accurate to the best of my knowledge
2. This notification is made in accordance with GDPR Article 33
3. Additional information will be provided as it becomes available

_____
Name: [Full Name]
Title: [Job Title]
Date: [YYYY-MM-DD]
Signature: [Digital/Physical]

CONTACT INFORMATION
===================
Primary Contact: [Name] - [Email] - [Phone]
Secondary Contact: [Name] - [Email] - [Phone]
Data Protection Officer: threatsimgpt@gmail.com
```

2.3 Follow-up Notification Protocol

Update Scenarios:

- **New information becomes available**
- **Risk assessment changes**
- **Additional data subjects identified**
- **Root cause determination**
- **Extended timeline requirements**

---

3. DATA SUBJECT NOTIFICATION PROTOCOL (GDPR Article 34)

3.1 Notification Trigger Matrix

Risk Level	Timeline	Method
CRITICAL/HIGH	Immediate (within 24 hours)	Direct email
MEDIUM	Within 72 hours	Email + In-app
LOW	Based on impact assessment	As appropriate

Notification Methods Priority:

1. **Direct email** (primary)
2. **In-app notification** (secondary)
3. **SMS/text message** (urgent cases)
4. **Physical mail** (last resort)
5. **Public notice** (when individual notification not feasible)

3.2 Individual Data Subject Notification Template

```
Subject: URGENT: Security Notice Regarding Your ThreatSimGPT Account
Reference: INC-2026-XXX
Date: [YYYY-MM-DD]

Dear [Customer Name],

SECURITY INCIDENT NOTIFICATION
==============================
We are writing to inform you of a security incident that may have affected your
personal information. This notice is being sent in accordance with applicable data
protection laws and our commitment to transparency.

INCIDENT SUMMARY
================
Incident Type: [Data Breach/System Compromise/Unauthorized Access]
Discovery Date: [YYYY-MM-DD]
Incident Period: [Start Date] to [End Date]

AFFECTED INFORMATION
====================
```

```
The following types of your personal information may have been affected:
[ ] Name and contact information
[ ] Email address
[ ] Account credentials (encrypted)
[ ] Usage and activity data
[ ] IP address and device information
[ ] Other: [Specify]

Information NOT affected:
[ ] Financial information
[ ] Social Security numbers
[ ] Government-issued IDs
[ ] Biometric data
[ ] Other: [Specify]

WHAT HAPPENED
==============
[Provide clear, factual description in plain language]
On [date], we discovered [brief description]. Our security team immediately
[containment actions]. We have engaged [external forensics firm if applicable] to
investigate the full scope.

WHAT WE ARE DOING
=================
Immediate Actions Taken:
1. [Action] - Completed [Date]
2. [Action] - Completed [Date]
3. [Action] - Completed [Date]

Ongoing Measures:
- [Measure 1]
- [Measure 2]
- [Measure 3]

ENHANCED SECURITY MEASURES
==========================
We have implemented the following additional security measures:
- [Security enhancement 1]
- [Security enhancement 2]
- [Security enhancement 3]

RECOMMENDED ACTIONS
===================
We strongly recommend you take the following steps immediately:

1. CHANGE YOUR PASSWORD
   Action Required: [Required/Recommended]
   Link to password reset: https://threatsimgpt.com/security
   Deadline: [Immediate/Within 24 hours/Within 7 days]

2. ENABLE TWO-FACTOR AUTHENTICATION
   Action Required: [Required/Recommended]
```

```
   Link to 2FA setup: https://threatsimgpt.com/security
   Deadline: [Immediate/Within 24 hours]

3. REVIEW ACCOUNT ACTIVITY
   Action Required: [Required/Recommended]
   Link to activity log: https://threatsimgpt.com/security
   Deadline: [Within 7 days]

4. MONITOR FOR SUSPICIOUS ACTIVITY
   Action Required: [Required/Recommended]
   What to look for: [List indicators]
   Duration: [Ongoing for 90 days]

PROTECTION AGAINST PHISHING
===========================
Be cautious of emails or messages claiming to be from ThreatSimGPT asking for:
- Passwords or security codes
- Financial information
- Personal identification details

We will NEVER ask for these via email. Always verify requests through our official
channels.

SUPPORT AND RESOURCES
=====================
Dedicated Support Channel:
- Email: security-support@threatsimgpt@gmail.com
- Phone: [Contact Number] (Available 24/7)
- Link to support portal: https://threatsimgpt.com/issues

Additional Resources:
- Security FAQ: https://threatsimgpt.com/blob/main/docs/SECURITY.md
- Identity Protection Guide: https://threatsimgpt.com/blob/main/docs/SECURITY.md
- Credit Monitoring Information: [Link if applicable]

YOUR RIGHTS
===========
Under applicable data protection laws, you have the right to:
- Request access to your personal data
- Request deletion of your account
- Lodge a complaint with supervisory authorities
- Seek compensation for damages

To exercise these rights, contact our Data Protection Officer:
Email: threatsimgpt@gmail.com
Phone: [Contact Number] (Available 24/7)

SUPERVISORY AUTHORITY NOTIFICATION
==================================
We have notified the relevant data protection authorities about this incident in
accordance with our legal obligations.
```

```
WE APOLOGIZE
============
We sincerely apologize for any concern or inconvenience this incident may cause.
Protecting your data is our highest priority, and we are committed to preventing
similar incidents in the future.

NEXT STEPS
===========
We will provide you with updates as:
- New information becomes available
- Our investigation progresses
- Additional protective measures are implemented

You can expect our next update by [Date] or sooner if significant developments occur.

Sincerely,

[Name]
[Title]
ThreatSimGPT Security Team

---
Data Protection Officer: threatsimgpt@gmail.com
Incident Reference: INC-2026-XXX
Date of Notice: [YYYY-MM-DD]

You have the right to lodge a complaint with a supervisory authority.
For a list of authorities, visit: https://threatsimgpt.com/blob/main/docs/compliance/
```

---

4. INTERNAL INCIDENT MANAGEMENT FRAMEWORK

4.1 Incident Response Team Structure

Core Incident Response Team (IRT)

Incident Commander (Primary)

- **Role:** Principal Security Compliance Engineer
- **Authority:** Overall incident coordination
- **Escalation:** CISO, CEO, Legal Counsel

Technical Lead

- **Role:** Senior Security Engineer
- **Authority:** Technical investigation and containment
- **Team:** Security engineering team

Communications Lead

- **Role:** Head of Communications
- **Authority:** All external and internal communications
- **Team:** PR, customer support, legal communications

Legal Counsel

- **Role:** Chief Legal Officer or designee
- **Authority:** Regulatory compliance and legal risk assessment
- **Team:** Legal department, external counsel

Data Protection Officer

- **Role:** DPO or privacy lead
- **Authority:** GDPR compliance and data subject rights
- **Team:** Privacy team

Business Continuity Lead

- **Role:** Operations Manager
- **Authority:** Business operations continuity
- **Team:** Operations, customer success

Support Teams

Forensics Team (Internal/External)

- Digital evidence collection and analysis
- Root cause investigation
- Timeline reconstruction

IT Infrastructure Team

- System isolation and recovery
- Log collection and preservation
- Network security measures

Customer Support Team

- Customer notification execution
- Support ticket management
- User inquiries response

HR Team (if applicable)

- Employee communications
- Internal policy compliance
- Personnel security measures

4.2 Incident Response Playbook

Phase 1: Detection and Analysis (0-2 hours)

Detection Triggers:

- Security monitoring alerts
- Anomalous system behavior
- External notifications
- Customer reports
- Internal discovery

Initial Assessment:

1. Verify incident authenticity
2. Determine scope and impact

3. Classify severity level
4. Activate appropriate response teams
5. Establish secure communication channels

Key Actions:

- Document initial findings
- Preserve evidence
- Activate incident response plan
- Notify core IRT members
- Establish incident timeline

Phase 2: Containment (2-6 hours)

Immediate Containment:

- Isolate affected systems
- Block unauthorized access
- Preserve forensic evidence
- Implement access controls
- Activate backup systems

Containment Strategy:

- Network segmentation
- Account lockdowns
- Data access restrictions
- System isolation
- Communication monitoring

Phase 3: Investigation (6-48 hours)

Forensic Analysis:

- Digital evidence collection
- Log analysis and correlation
- Timeline reconstruction
- Root cause identification
- Impact assessment

Investigation Focus:

- Attack vector identification
- Data exfiltration analysis
- System vulnerability assessment
- Compromise scope determination
- Attribution analysis (if applicable)

Phase 4: Eradication and Recovery (24-72 hours)

System Remediation:

- Vulnerability patching
- Malware removal
- Configuration hardening
- Access control updates

- Security enhancements

Data Recovery:

- System restoration from clean backups
- Data integrity verification
- Service restoration testing
- Performance monitoring
- Security validation

Phase 5: Notification and Reporting (Concurrent)

Regulatory Notification:

- Authority notification within required timelines
- Complete regulatory reporting
- Documentation preservation
- Compliance verification

Customer Communication:

- Affected user notification
- Public communication (if required)
- Support channel activation
- FAQ and resource preparation

Phase 6: Post-Incident Activities (72+ hours)

Lessons Learned:

- Incident timeline finalization
- Root cause analysis documentation
- Response effectiveness assessment
- Improvement opportunity identification
- Framework updates

Security Improvements:

- Control enhancements
- Process improvements
- Technology upgrades
- Training updates
- Monitoring improvements

---

5. COMPLIANCE AND AUDIT REQUIREMENTS

5.1 Documentation Requirements

Mandatory Documentation:

- Incident timeline and chronology
- Risk assessment documentation
- Notification copies and receipts
- Authority correspondence
- Forensic reports and analysis

- Remediation action logs
- Lessons learned documentation
- Compliance verification records

Retention Requirements:

- **Incident records:** 7 years minimum
- **Forensic evidence:** 3 years minimum
- **Notification records:** 7 years minimum
- **Training records:** 3 years minimum
- **Policy documents:** Current + 3 previous versions

5.2 Audit Trail Requirements

Comprehensive Logging:

- All incident response actions
- Decision-making processes
- Communication records
- Authority notifications
- System changes
- Access modifications
- Data transfers

Audit Evidence:

- Timestamped action logs
- Communication transcripts
- Decision documentation
- Regulatory submissions
- Internal approvals

---

6. TRAINING AND AWARENESS

6.1 Incident Response Team Training

Core Competencies:

- GDPR compliance requirements
- Incident response procedures
- Communication protocols
- Technical investigation skills
- Risk assessment methodologies

Training Frequency:

- **Initial training:** On appointment
- **Refresher training:** Quarterly
- **Scenario exercises:** Bi-annual
- **Cross-functional drills:** Annual

6.2 General Staff Awareness

Security Awareness Topics:

- Data breach identification
- Reporting procedures
- Phishing prevention
- Data handling best practices
- Privacy protection measures

Training Requirements:

- **New hire orientation:** Within 30 days
- **Annual refresher:** All staff
- **Role-specific training:** As needed
- **Policy updates:** Immediately upon changes

---

7. CONTINUOUS IMPROVEMENT

7.1 Framework Review Process

Review Schedule:

- **Quarterly reviews:** Operational procedures
- **Semi-annual assessments:** Framework effectiveness
- **Annual comprehensive review:** Full framework validation
- **Ad-hoc reviews:** Post-incident lessons learned

Review Criteria:

- Regulatory compliance alignment
- Operational effectiveness
- Team performance metrics
- Technology integration
- Industry best practices

7.2 Metrics and KPIs

Response Metrics:

- **Mean Time to Detect (MTTD)**
- **Mean Time to Respond (MTTR)**
- **Notification compliance rate**
- **Containment effectiveness**

Quality Metrics:

- **Framework adherence rate**
- **Training completion rate**
- **Audit compliance score**
- **Customer satisfaction**

---

8. TECHNOLOGY INTEGRATION

8.1 Security Stack Alignment

Detection Technologies:

- SIEM systems for correlation and alerting
- EDR solutions for endpoint protection
- DLP platforms for data loss prevention
- IAM systems for access management

Response Tools:

- Automated containment systems
- Communication platforms
- Documentation tools
- Case management systems

8.2 Automation Opportunities

Automated Processes:

- Incident classification based on predefined criteria
- Template population with incident-specific data
- Regulatory deadline tracking and escalation
- Compliance verification and audit trail generation

Integration Points:

- Security monitoring systems
- Communication platforms
- Documentation repositories
- Regulatory submission portals

---

9. CONTACT INFORMATION

9.1 Emergency Contacts

Primary Response Team:

- **Incident Commander:** [Name/Contact]
- **Technical Lead:** [Name/Contact]
- **Communications Lead:** [Name/Contact]
- **Legal Counsel:** [Name/Contact]
- **Data Protection Officer:** threatsimgpt@gmail.com

External Contacts:

- **Legal Counsel:** [Contact Information]
- **Forensic Partners:** [Contact Information]
- **Cyber Insurance:** [Contact Information]

- **Regulatory Authorities:** [Contact Information]

9.2 Support Channels

Internal Support:

- **Security Team:** threatsimgpt@gmail.com
- **IT Help Desk:** [Contact Information]
- **Legal Department:** [Contact Information]

External Support:

- **Emergency Hotline:** [Contact Number]
- **Email Support:** threatsimgpt@gmail.com
- **Web Portal:** https://threatsimgpt.com/support

---

10. DOCUMENT VERSION CONTROL

10.1 Revision History

Version	Date	Changes	Author
1.0	March 15, 2026	Initial framework creation	Jeremiah Okino

10.2 Approval Matrix

Role	Name	Date	Signature
Owner	ThreatSimGPT		
Author	Jeremiah Okino		
Reviewer	ThreatSimGPT Team		
Approver	ThreatSimGPT Team		

10.3 Distribution List

- **Executive Team**
- **Security Team**
- **Legal Department**
- **Compliance Team**
- **Data Protection Officer**
- **External Counsel** (as required)

© 2026 ThreatSimGPT. All rights reserved.

Document Classification: Internal Use - Confidential
Next Review Date: September 15, 2026

Document Owner: ThreatSimGPT
Contact: threatsimgpt@gmail.com

This framework is a living document and will be updated as regulatory requirements evolve and organizational needs change. All personnel are responsible for maintaining awareness of the current version and implementing its requirements.